

Question 4

Use this framework to complete a Cyber Security policy document for a company of your choice. (30)

CYBER SECURITY POLICY AND PROCEDURES

Purpose

The purpose of this policy is to establish the guidelines for computer security and the protection of an organization's networks and its content or knowledge base and to minimize the risk of internal and external cyber threats.

Scope

This policy applies to all employees, contractors, consultants, and others specifically authorized to access information and associated assets owned, operated, controlled, or managed by the company.

Policy

The company is committed to building a strong cybersecurity program to support, maintain, and secure critical infrastructure and data systems. To achieve this, the company will identify, evaluate, and take steps to avoid or mitigate risk to the company's information assets and prevent unauthorized digital or physical access, damage, theft, compromise, or interference with the company's information systems and facilities.

1. Responsibilities

CTO – Chief Technology Officer

- Set policies in place to maintain security
- Keep up with attackers and technology to stay ahead of threats
- Ensure security is a culture within the company
- Layout clear instructions for all team members to follow in the event of an incident response

IT Manager

- Ensure policies are followed
- Ensure protocols for breaches and post breach are practiced and rehearsed
- Ensure all team members have, and know their responsibilities both in securing data and during an incident response
 - Ensure adherence with government policies.
 - Together with security and development teams the IT managers will be responsible for ensuring backups are made and available and confirming the integrity of the data.

Dev team

- Our policy is sec-dev-ops, security is a culture within the company and all development policies shall be implemented with this in mind
- Both SAST (whitebox testing) and DAST (Blackbox testing) will be rigorously implemented to ensure bugs, vulnerabilities and glitches are found and fixed prior to deployment
- Use of AI in coding is prohibited unless otherwise specified by team leads as this technology can only be used when we are sure it will not collect data on our code, which is proprietary, as well as any confidential data that may be processed as a result.

Security team

- Investigate all security claims.
- Help maintain security standards across the company.
- Update security policies as new threats rise.
- Advise on ways to increase security around the company
- Insure protocols for incident responses is well practiced and rehearsed
- Ensure confidentiality is maintained across all levels of the company
- Maintain security policies that all employees are to follow
- Simulate attacks to find vulnerabilities and weaknesses within our systems.
- Ensure all employees scope of data is limited to only the data they need.
-

Human Resources

- Ensure all staff are vetted
- Work with security to ensure policies are followed around social media, data transmission and data storage.
- Assist in ensuring all employees scope of data is limited to only the data they need.

Accounting

- All financial data is to be treated as confidential unless otherwise stated
- All payments are to go through only official channels and are to be double checked before payment is made
- All funds moved should have the ability to be traced back.

All Staff

- To protect data and enforce security measures.
- Be on the lookout for suspicious activity

2. Standards

We here at Secdev IT solutions are trusted by our clients to develop IT solutions to suit their needs and therefore our clients expect us to handle their data with the utmost care and security. Any breaches in data could lead to reluctance from new clients and therefore data breaches are seen as a

threat to the company. All employees are required to take security very seriously with the understanding that falling to do so will result in consequences including contract termination.

- Report all suspicious activity to the security team
- Guard your own personal data to avoid breaches and spear Phishing.
- Follow security policies to ensure safety and standards are maintained

3. Asset Management

Asset management is of paramount importance. Not only does this maintain security over attackers main gateway but it also makes sure we are in compliance with governance, as our clients customer data is one of our biggest assets the POPI act also applies here.

All endpoints are to be updated and patched as soon as humanly possible, although asset management systems will be used to automate, security team should follow through and ensure all systems are up to date. This holds extra importance in the case of air gapped systems, should a solution arise that allows these systems to be patched and reintroduced into the system in a safe manner the security team should be aware and follow guidelines to do so.

For mobile phones we will implement a CYOD (choose your own device) policy, this will come with installed software to maintain security such as geo-locking data and have a our software detect movement of confidential data as well as confidential data wipes in cases of lost devices.

All computers will use a combination of password managers, biometrics, authenticator apps and key fobs where applicable. A minimum of two factors of authentication s required to access any endpoints.

Out of date devices are to be handed over to security for decommissioning and destruction.

Only company approved networks are to be used.

4. Awareness and Training

Training will start during onboarding and will be ongoing to keep all staff aware of ne threats and tactics employed by attackers

Occasional phishing tests will be undertaken by our security teams with incentives for those who succeed and training for those who would need it.

Awareness training will continually be made available and will include policies such as:

- All devices must have passwords
- All devices must have MFA
- Lock devices when unattended
- Password management and rotation

5. Data Security

Data Storage

We will use cloud storage for both backup use and collaboration purposes

The policy of least privilege will be used to determine data access

The company will provide external storage devices. These will only be used with company computers and are prohibited for personal use and on personal devices.

We will implement programs to classify data as

- Top secret
- Secret
- confidential

Data that will fall under these classifications will be:

- Client Data
- Vendor Data
- Proprietary data
- Private financial information

Customer data is meant to be stored only

- If required by law or contract
- If the responsible party needs it for lawful purposes
- If the data subject or their legal representative consents
- For historical, statistical, or research purposes, if safeguards are in place

In order to be in compliance with POPIA

Data Transmission

- All data is to be transmitted on secure channels and using encryption.
- Do not transfer data while using unsecured networks for example public Wi-Fi.
- When moving data using physical storage devices a clear chain of ownership should be established to show how the data moved and who had it, both for security and accountability.
- Avoid transferring data between users and accounts unless it is deemed necessary.

Extra steps will be taken when working remotely to ensure data is not intercepted such as

Encryption

Hashing

Extra steps for authentication

Vulnerability scans

Data Destruction

- All drives containing top secret data are to be destroyed through incineration or crushing with a certificate required to prove correct procedures were followed
- All data drives are to undergo data erasure with at least 3 passes if they contain secret tier confidentiality and below

Ensure none of the information can be reconstructed, this is recommended by the POPI act

6. Information Protection Processes and Procedures

is recommended by the POPI act

Secure Software Development

- Both SAST (whitebox testing) and DAST (Blackbox testing) will be rigorously implemented to ensure bugs, vulnerabilities and glitches are found and fixed prior to deployment
- Full authentication will be required before being authorized to contribute to projects
- Version control will be heavily enforced to keep parity and the ability to roll back projects if the need arises

- Multifactor authentication will be required before accessing version control repositories.

Contingency Planning

- A cold site will be maintained for essential staff who may not be able to work remotely
- For those who are able to work remotely alternative routes to cloud backups and repositories will be made available.

Network Infrastructure

- we will rely on a vpn within a wan to secure and share data through our network and the cloud

Network Servers

- servers will require authentication before accessing
- local backups of projects should be kept of either the most recent 6 months or the length of a project, whichever of the two is longer
- cloud technology will be our main source of storage, backup and collaboration.

Network Segmentation

- Each department will be segmented into its own vlan
- Authorization will be required to send confidential and higher tier security documents across vlans

[Disk encryption setup]

Services such as bitlocker are to be used on all company drives to encrypt data

[Password management tool setup]

- A password manager will be provided to you, all employees are required to use it and make use of the suggested passwords it provides.
- Passwords to the password manager will be monitored by our security team
- The security team will enforce password rotation, complexity and minimum and maximum tomes for passwords which ALL employees are to adhere to
- CYOD issued company devices will also be subject to password rules.
-

[Installation of antivirus/ anti-malware software]

- All company machines will come with antivirus and anti-malware installed.
- Firewalls will also be enabled and can only be disabled by the security team.
- Vulnerability and anomaly detection systems will also be done by our systems to ensure the machines are used correctly.
- All these security systems will be monitored and updated remotely,
- all staff are to assist the security team to help maintain these security standards

7. Protective Technology

Email Filtering

- Inbound and outbound emails will be scanned for sensitive data as well as malware.
- There will be filters to keep out phishing, spam and suspicious emails but should you receive any email you are unsure about please report it so the security team can check it and either approve it or amend it to the filtering list.

Internet Filtering

- Traffic from certain websites will be blocked, this includes entertainment streaming services, explicit content, gambling sites and sites outside our guidelines such as unapproved AI sites.
- Unapproved vpns will also not be allowed as well as any other methods to attempt to circumnavigate our internet firewall restrictions.

Network Vulnerability Assessments

- Attestation will be implemented to ensure end points are up to date and maintained.
- Vulnerability and anomaly detection systems will also be done by our systems to ensure the machines are used correctly.

8. Anomalies and Events

In the case of an event each team should follow their incident response guidelines

Universally all guidelines will include

- Preparation: Create a plan before a breach occurs so you can respond quickly and efficiently
- Identification: Monitor data for anomalies that indicate a security breach
- Detection and analysis: Verify the incident and assess its impact
- Containment: Limit the damage by preventing the attacker from communicating with the network
- Eradication: Identify and remove the root cause of the incident
- Recovery: Bring affected systems back into production without causing another incident
- Post incident activity: Determine what happened, why it happened, and how to prevent it from happening again

Anomaly detection software combined with AI will be used to detect unusual behavior in our systems. This will go along with manual reporting from our staff.

9. Security Continuous Monitoring

Anti-Malware Tools

- Anti malware tools will come preinstalled this will range from OS preinstalled anti-malware to third party anti-malware such as avast or Malwarebytes

Patch management.

- Attestation and remote security management will ensure devices are up to date.
- In the event that a patch cannot be found the security team will make an assessment as whether controls should be applied such as air-gapping systems of the systems should be decommissioned

10. Response Planning

In the case of an incident, each teams respective response plan will be initiated however all teams response plans should include

- Preparation: Create a plan before a breach occurs so you can respond quickly and efficiently
- Identification: Monitor data for anomalies that indicate a security breach
- Detection and analysis: Verify the incident and assess its impact
- Containment: Limit the damage by preventing the attacker from communicating with the network
- Eradication: Identify and remove the root cause of the incident
- Recovery: Bring affected systems back into production without causing another incident
- Post incident activity: Determine what happened, why it happened, and how to prevent it from happening again

Electronic Incidents

- These will mainly be handled by our cybersecurity teams
- Reports will be required after each incident which include causes and prevention.

Physical Incidents

- These will mainly be handled by our site security team and cybersecurity team if needed.
- Reports will be required after each incident which include causes and prevention.

Notification

- All devices will have notifications enabled and will be sent out with varying degrees of alert based on severity.

11. Recovery & Restoration

As our infrastructure will remain decentralized and our services will be based on deadlines and less often direct service to our clients, we have deemed the major threat would be data breaches and less likely to be denial of service attacks as this would have less impact on our output. As such we will use the following policies for restoration and recovery

- A cold site with minimal required equipment will be maintained for essential staff who will not be working remotely in event of an incident.
- In the event of an attack our goal will be to get our services back to the minimum required level to continue work in a reasonable manner.
- Local copies will be kept of all recent (within the last 6 months or the duration of a current project) and cloud copies of all data will also be maintained in the cloud, should the need arise backups will be restored from these sources

12. Confidentiality and Non-Disclosure Agreement

All information in these policies and all proprietary information and client data is considered confidential. By signing this document you acknowledge that you have read and accept to follow the policies stated in this document and you accept the consequences of violating these policies.

This Nondisclosure Agreement (the "Agreement") is entered into by and between _____, with its principal offices at _____, and _____, with its principal offices at _____, collectively referred to as the "parties" for the purpose of preventing the unauthorized disclosure of Confidential Information as defined below. The parties agree to enter into a confidential relationship with respect to the disclosure by one or each (the "Disclosing Party") to the other (the "Receiving Party") of certain proprietary and confidential information (the "Confidential Information").

This is the entire Agreement between the parties. It replaces and supersedes any and all oral agreements between the parties, as well as any prior writings. Furthermore This Agreement may not be amended except in a written agreement signed by both parties.

This Agreement and each party's obligations shall be binding on the representatives, assigns, and successors of such party. Each party has signed this Agreement through its authorized representative.

Disclosing Party

By: _____

Printed Name: _____

Title: _____

Dated: _____

Receiving Party

By: _____

Printed Name: _____

Title: _____

Dated: _____